

Encuesta Integral sobre Indicadores y Métricas ISO/IEC 27001:2022

Objetivo: comprender cómo su organización diseña, aplica y gobierna indicadores y métricas de ciberseguridad alineados con ISO/IEC 27001:2022 y el contexto regulatorio europeo (incluida NIS2), con especial atención al entorno español.

1. Información general de la organización

1.1 Tipo de organización

Seleccione la opción que mejor describa su organización:

- ☐ Administración pública (estatal)
- ☐ Administración pública (autonómica)
- ☐ Administración pública (local)
- ☐ Empresa privada – gran empresa (> 250 empleados)
- ☐ Empresa privada – pyme
- ☐ Operador de servicios esenciales / entidad importante (NIS2)
- ☐ Proveedor de servicios digitales / cloud
- ☐ Otra (especificar): ____

1.2 Sector principal

- ☐ Sanitario
- ☐ Energía
- ☐ Transporte
- ☐ Banca / servicios financieros
- ☐ Educación / I+D
- ☐ Industria / manufactura
- ☐ TIC / telecomunicaciones
- ☐ Administración pública general
- ☐ Otro (especificar): ____

1.3 Ámbito geográfico de operación

- ☐ Principalmente España
- ☐ España y otros países de la UE
- ☐ Global (incluye fuera de la UE)

1.4 Estado de certificación / alineamiento ISO/IEC 27001

- ☐ Certificado ISO/IEC 27001:2013
- ☐ Certificado ISO/IEC 27001:2022
- ☐ En proceso de certificación (previsto < 12 meses)
- ☐ Alineado sin certificación formal
- ☐ No alineado actualmente

2. Gobernanza del SGSI y sistema de indicadores

2.1 ¿Dispone su organización de un sistema formal de indicadores de seguridad de la información (KPIs/KRIs/otros) documentado y aprobado?

- ☐ Sí, formalmente definido, documentado y aprobado por la alta dirección
- ☐ Parcialmente definido, sin aprobación formal
- ☐ En fase de diseño
- ☐ No disponemos de un sistema formal de indicadores

2.2 ¿Con qué frecuencia se revisan los indicadores del SGSI en órganos de gobierno (comité de seguridad, comité de riesgos, comité de dirección)?

- ☐ Mensualmente
- ☐ Trimestralmente
- ☐ Semestralmente
- ☐ Anualmente
- ☐ Solo en auditorías o ante incidentes graves
- ☐ No se revisan de forma sistemática

2.3 ¿Qué tipos de indicadores utiliza de forma habitual? (marque todos los que apliquen)

- ☐ Indicadores de rendimiento (KPIs) del SGSI
- ☐ Indicadores clave de riesgo (KRIs)
- ☐ Indicadores de cumplimiento normativo / auditoría
- ☐ Indicadores de madurez (modelos tipo CMMI, propios u otros)
- ☐ Ninguno de los anteriores / no formalizados

2.4 ¿Existe una política o procedimiento específico que regule el diseño, aprobación y mantenimiento de indicadores de seguridad?

- ☐ Sí, política formal específica
- ☐ Sí, incluido como sección dentro de otra política/procedimiento
- ☐ No, se gestiona de forma informal
- ☐ No existe

2.5 ¿En qué medida considera que su sistema de indicadores cubre los objetivos de seguridad definidos en su SGSI?

- ☐ Cobertura muy alta (≥ 80 % de los objetivos)
- ☐ Cobertura alta (60–79 %)
- ☐ Cobertura moderada (40–59 %)
- ☐ Cobertura baja (< 40 %)
- ☐ No se ha realizado este análisis

3. Diseño de indicadores: enfoque y metodologías

3.1 ¿Qué criterios utiliza para definir indicadores (por ejemplo, SMART: específicos, medibles, alcanzables, relevantes, acotados en el tiempo)?

- ☐ Uso sistemático de criterios formales (SMART u otros)
- ☐ Uso ocasional o parcial de criterios formales
- ☐ Se definen de forma ad hoc, sin marco explícito
- ☐ No se utilizan criterios definidos

3.2 ¿Se basa su organización en estándares o guías externas para diseñar indicadores? (marque todos los que apliquen)

- ☐ ISO/IEC 27001:2022 (cláusula 9.1)
- ☐ ISO/IEC 27004 (medición de seguridad de la información)
- ☐ Guías de ISACA sobre sistemas de KPIs de seguridad
- ☐ Guías de ENISA u organismos nacionales (INCIBE, CCN, etc.)
- ☐ Otras guías sectoriales
- ☐ No se emplean referencias externas

3.3 Cuando diseña un indicador nuevo, ¿cuál de las siguientes prácticas describe mejor su enfoque dominante?

- ☐ Partimos de objetivos de negocio y de seguridad claramente definidos y derivamos indicadores
- ☐ Partimos de los datos técnicos disponibles y construimos indicadores “a posteriori”
- ☐ Una mezcla razonablemente equilibrada de ambos
- ☐ Principalmente por exigencias regulatorias o de auditoría

3.4 ¿Qué peso tienen las siguientes dimensiones en su sistema de indicadores?
(Valore de 1 = peso muy bajo a 5 = peso muy alto)

- Riesgo (KRIs): ____ / 5
- Rendimiento/eficacia (KPIs): ____ / 5
- Cumplimiento normativo: ____ / 5
- Madurez / capacidad: ____ / 5
- Resiliencia / continuidad: ____ / 5

3.5 ¿Se calculan indicadores cuantitativos (porcentajes, tasas, ratios) o predominan los indicadores cualitativos?

- ☐ Predominan claramente los cuantitativos
- ☐ Mezcla equilibrada de cuantitativos y cualitativos
- ☐ Predominan claramente los cualitativos
- ☐ No se ha evaluado

4. Indicadores estratégicos y de madurez del SGSI

4.1 ¿Dispone su organización de un indicador global de madurez del SGSI (por ejemplo, porcentaje de cumplimiento de controles, modelos de madurez)?

- ☐ Sí, indicador cuantitativo consolidado (por ejemplo, % de madurez $\geq X$)
- ☐ Sí, pero solo cualitativo (niveles bajo/medio/alto)
- ☐ No, pero está en desarrollo
- ☐ No, ni existe ni se prevé a corto plazo

4.2 ¿Con qué frecuencia se presenta el indicador de madurez del SGSI a la alta dirección?

- ☐ Mensualmente
- ☐ Trimestralmente
- ☐ Semestralmente
- ☐ Anualmente
- ☐ Solo a petición
- ☐ No se presenta

4.3 ¿Se utiliza algún tipo de ROI (retorno de inversión) o indicador económico para evaluar iniciativas de seguridad?

- ☐ Sí, ROI de la seguridad calculado de forma regular
- ☐ Sí, pero solo para proyectos específicos
- ☐ No, pero nos gustaría establecerlo
- ☐ No, y no está en la agenda

4.4 ¿En qué grado considera que los indicadores estratégicos influyen en la toma de decisiones de inversión en seguridad?

- ☐ Influencia decisiva
- ☐ Influencia importante
- ☐ Influencia limitada
- ☐ Influencia marginal o simbólica
- ☐ No influyen

5. Gestión de riesgos e indicadores asociados

5.1 ¿Dispone su organización de indicadores que midan el estado del proceso de gestión de riesgos de seguridad de la información?

- ☐ Sí, múltiples indicadores (progreso, riesgos residuales, etc.)
- ☐ Sí, uno o dos indicadores clave
- ☐ No, se gestiona sin indicadores explícitos

5.2 Indique qué indicadores se utilizan (marque todos los que apliquen):

- ☐ % de activos críticos con análisis de riesgos actualizado
- ☐ % de riesgos tratados dentro del plazo acordado
- ☐ % de riesgos residuales por encima del apetito de riesgo aprobado
- ☐ Número de excepciones de riesgo aprobadas y abiertas
- ☐ Otros (especificar): _____

5.3 ¿Con qué frecuencia se actualizan los indicadores de riesgos?

- ☐ Mensual
- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo tras auditorías o incidentes

5.4 ¿Se integran sus indicadores de riesgos con otros marcos (por ejemplo, NIS2, DORA, Solvencia II, Basilea, etc.)?

- ☐ Sí, explícitamente
- ☐ Parcialmente / de forma informal
- ☐ No, y no se ha planteado
- ☐ No, pero está en análisis

6. Controles técnicos, vulnerabilidades y métricas operativas

6.1 ¿Dispone su organización de indicadores sobre gestión de vulnerabilidades y parches?

- ☐ Sí, con objetivos formales (SLAs de parcheo, umbrales, etc.)
- ☐ Sí, pero sin objetivos formales
- ☐ No

6.2 ¿Qué indicadores de vulnerabilidades/patching aplica? (marque todos los que apliquen)

- ☐ Tiempo medio de corrección de vulnerabilidades críticas (MTTR)
- ☐ % de sistemas con vulnerabilidades críticas corregidas en plazo
- ☐ % de sistemas con software en versiones soportadas
- ☐ % de activos expuestos a internet con vulnerabilidades críticas abiertas
- ☐ Otros (especificar): _____

6.3 ¿Se dispone de indicadores de “higiene” básica (endpoints, antivirus, configuración segura, etc.)?

- ☐ Sí, cobertura de antivirus/EDR en endpoints
- ☐ Sí, cumplimiento de configuraciones seguras (CIS, STIG, etc.)
- ☐ Sí, nivel de cifrado en dispositivos y canales de comunicación
- ☐ No se miden de forma sistemática

6.4 ¿Con qué periodicidad se revisan estos indicadores técnicos?

- ☐ Diaria
- ☐ Semanal
- ☐ Mensual
- ☐ Trimestral
- ☐ Menos frecuente

7. Monitorización, SOC e incidentes

7.1 ¿Qué indicadores relativos a incidentes de seguridad se utilizan?

- ☐ N° de incidentes de seguridad (por severidad)
- ☐ Tiempos de detección (MTTD) y respuesta (MTTR)
- ☐ % de incidentes resueltos dentro de SLA
- ☐ Tasa de reincidencia de incidentes por causa
- ☐ N° de sistemas vulnerables detectados proactivamente
- ☐ Otros (especificar): ____

7.2 ¿En qué medida se alinean sus indicadores de incidentes con los formatos y requisitos de reporte a CERT u organismos nacionales (por ejemplo, INCIBE-CERT, CCN-CERT)?

- ☐ Totalmente alineados
- ☐ Parcialmente alineados
- ☐ Mínimamente alineados
- ☐ No alineados

7.3 ¿Utiliza la organización indicadores de desempeño del SOC o funciones de monitorización?

- ☐ Sí, indicadores de cobertura de fuentes, correlación y disponibilidad de herramientas
- ☐ Sí, pero solo orientados a volumen de eventos
- ☐ No, el SOC no dispone de KPIs definidos
- ☐ No tenemos SOC / función similar

7.4 ¿Se utilizan indicadores para medir la eficacia de las capacidades de detección avanzada (por ejemplo, EDR, NDR, threat hunting)?

- ☐ Sí, y son revisados regularmente
- ☐ Sí, pero sin un ciclo formal de revisión
- ☐ No, se mide de forma ad hoc
- ☐ No se mide

8. Concienciación, formación y comportamiento del usuario

8.1 ¿La organización mide la participación y efectividad de la formación en seguridad?

- ☐ Sí, con indicadores cuantitativos y objetivos
- ☐ Sí, pero solo se mide asistencia
- ☐ No se mide

8.2 ¿Qué indicadores se utilizan? (marque todos los que apliquen)

- ☐ % de empleados que completan formación obligatoria
- ☐ Resultados medios en evaluaciones de conocimiento
- ☐ % de nuevos empleados formados en plazo
- ☐ Tasas de clic en campañas de phishing simulado
- ☐ N° de reportes de phishing legítimos por parte de usuarios
- ☐ Otros (especificar): ____

8.3 ¿Con qué frecuencia se presentan estos indicadores a la dirección?

- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo a petición
- ☐ No se presentan

8.4 ¿Existe algún incentivo o consecuencia (positiva o negativa) asociado a estos indicadores?

- ☐ Sí, incentivos formales (reconocimientos, objetivos de desempeño, etc.)
- ☐ Sí, consecuencias en evaluación de desempeño
- ☐ No, pero se está valorando
- ☐ No, ni está previsto

9. Continuidad de negocio y resiliencia

9.1 ¿Dispone de indicadores relacionados con continuidad de negocio y recuperación ante desastres?

- ☐ Sí, definidos y aprobados (RTO/RPO, pruebas, etc.)
- ☐ Sí, pero de forma fragmentada
- ☐ No

9.2 ¿Qué indicadores se utilizan? (marque todos los que apliquen)

- ☐ % de procesos críticos con planes de continuidad actualizados
- ☐ % de pruebas de continuidad realizadas vs planificadas
- ☐ Cumplimiento de RTO y RPO en pruebas realizadas
- ☐ N° de desviaciones críticas detectadas en pruebas
- ☐ Otros (especificar): ____

9.3 ¿Con qué frecuencia se revisan y actualizan estos indicadores?

- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo tras pruebas mayores o incidentes reales

10. Proveedores, terceros y cadena de suministro

10.1 ¿Se mide el desempeño de seguridad de proveedores y terceros críticos?

- ☐ Sí, con indicadores definidos (SLAs, resultados de auditorías, etc.)
- ☐ Sí, pero de forma informal
- ☐ No

10.2 ¿Qué indicadores se utilizan? (marque todos los que apliquen)

- ☐ % de proveedores críticos evaluados y aprobados
- ☐ % de proveedores con cláusulas de seguridad alineadas a ISO 27001
- ☐ Nº de incumplimientos de SLAs de seguridad por proveedor
- ☐ Nº de incidentes relacionados con terceros
- ☐ Otros (especificar): _____

10.3 ¿Se integran los indicadores de terceros en el cuadro de mando global del SGSI?

- ☐ Sí, plenamente
- ☐ Parcialmente
- ☐ No, se gestionan por separado
- ☐ No existen indicadores de terceros

11. Integración con el entorno regulatorio (NIS2, GDPR, etc.)

11.1 ¿En qué medida considera que sus indicadores apoyan el cumplimiento de NIS2 (si aplica)?

- ☐ Muy alineados (cobertura explícita de requisitos de NIS2)
- ☐ Moderadamente alineados
- ☐ Ligeramente alineados
- ☐ No alineados / no analizado

11.2 ¿Se emplean indicadores específicos relacionados con protección de datos (GDPR/LOPDGDD)?

- ☐ Sí, número y gravedad de brechas de datos
- ☐ Sí, tiempos de notificación a autoridades
- ☐ Sí, cumplimiento de derechos de los interesados
- ☐ No, o no de forma sistemática

11.3 ¿Utiliza su organización indicadores nacionales o europeos (por ejemplo, estadísticas de INCIBE, ENISA) como referencias o benchmarks?

- ☐ Sí, sistemáticamente
- ☐ Sí, ocasionalmente
- ☐ No, pero sería de interés
- ☐ No, y no se considera relevante

12. Automatización, herramientas y calidad de datos

12.1 ¿En qué grado está automatizada la recopilación de datos para sus indicadores?

- ☐ Altamente automatizada (≥ 80 % de los datos)
- ☐ Moderadamente automatizada (40–79 %)
- ☐ Poco automatizada (< 40 %)
- ☐ Manual en su mayor parte

12.2 ¿Qué herramientas utilizan para el cálculo y reporte de indicadores?

- ☐ Herramientas GRC específicas
- ☐ Herramientas de BI / cuadros de mando corporativos
- ☐ Hojas de cálculo (Excel, etc.)
- ☐ Herramientas internas desarrolladas ad hoc
- ☐ Otros (especificar): _____

12.3 ¿Evalúan la calidad de los datos utilizados para los indicadores (completitud, exactitud, consistencia, trazabilidad)?

- ☐ Sí, mediante procesos formales
- ☐ Sí, de forma informal
- ☐ No, se asume la calidad de los datos

12.4 ¿Se han identificado problemas relevantes de calidad de datos que afecten a sus indicadores?

- ☐ Sí, con impacto significativo en decisiones
- ☐ Sí, pero de impacto limitado
- ☐ No se han identificado
- ☐ No se ha analizado

13. Reporte, comunicación y uso práctico de los indicadores

13.1 ¿Quiénes son los principales receptores de los informes de indicadores de seguridad? (marque todos los que apliquen)

- ☐ Alta dirección / Consejo
- ☐ Comité de riesgos / auditoría
- ☐ CISO / responsables de seguridad
- ☐ Responsables de negocio / unidades operativas
- ☐ Reguladores / supervisores
- ☐ Otros (especificar): ____

13.2 ¿Con qué frecuencia reciben estos informes?

- ☐ Mensual
- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Ad hoc

13.3 ¿En qué medida considera que los indicadores influyen realmente en las decisiones de gestión?

- ☐ Alta influencia: se utilizan para priorizar acciones y recursos
- ☐ Influencia moderada: se usan como apoyo
- ☐ Influencia baja: más bien decorativos
- ☐ No influyen / no se usan

13.4 ¿Se comunican indicadores simplificados o “versiones ejecutivas” a públicos no técnicos?

- ☐ Sí, con adaptación de lenguaje y formato
- ☐ A veces, sin una estrategia clara
- ☐ No, se presenta la misma información a todos

14. Futuro, mejora y visión estratégica

14.1 ¿Qué áreas considera prioritarias para mejorar su sistema de indicadores en los próximos 2 años?

- ☐ Mejor alineamiento con objetivos de negocio
- ☐ Mejora de automatización y calidad de datos
- ☐ Mayor énfasis en indicadores de resiliencia
- ☐ Simplificación y racionalización de indicadores existentes
- ☐ Incorporación de indicadores económicos (ROI, coste del riesgo)
- ☐ Integración con requisitos de NIS2 / reguladores
- ☐ Otros (especificar): ____

14.2 Finalmente, ¿cómo calificaría el grado de madurez global de su sistema de indicadores de seguridad?

- ☐ Nivel 1: Reactivo – indicadores escasos, centrados en incidentes
- ☐ Nivel 2: Básico – indicadores definidos pero fragmentados
- ☐ Nivel 3: Definido – sistema estructurado, integrado en el SGSI
- ☐ Nivel 4: Gestionado – indicadores influyen en decisiones de forma sistemática
- ☐ Nivel 5: Optimizado – medición avanzada, análisis predictivo, mejora continua basada en datos

14.3 Comentarios adicionales, confesiones, lamentos o ideas brillantes que no cabían en las casillas anteriores: